



SecureScan

KISA 기준 기반 SAST MVP

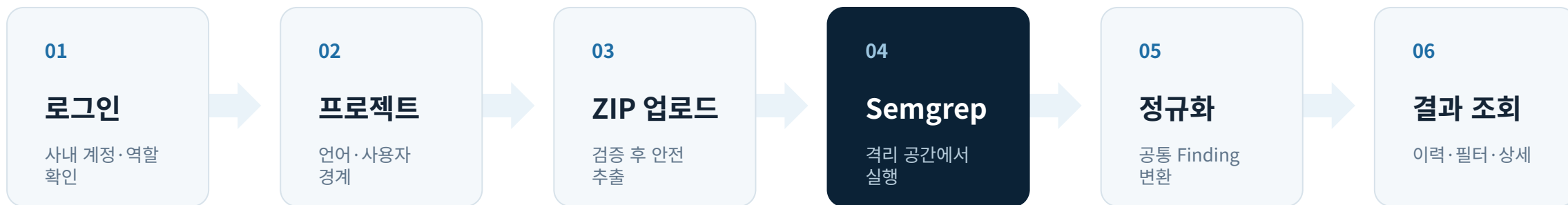
정적 애플리케이션 보안 진단 프로그램 MVP 개발 중간발표

Java · JavaScript · Python | FastAPI · Semgrep · SQLAlchemy

중간점검 | 2026.08.30

요구사항을 기능별로 묶어 설계·구현·검증했습니다

업로드부터 결과까지 하나의 흐름으로 연결했습니다



설계 원칙

분석 엔진은 Semgrep 하나로 고정하고, 엔진 결과와 화면 사이에 정규화 계층을 두었습니다.

따라서 언어나 규칙이 늘어나더라도 프로젝트·분석 이력·Finding 조회 흐름은 그대로 재사용합니다.

로그인 한 번에 계정 보호와 역할 통제를 함께 적용했습니다

인증 요청이 처리되는 순서

01

회사 이메일 검증

@company.com 형식만 허용

02

bcrypt 해시 비교

평문 비밀번호는 저장하지 않음

03

서명 쿠키 발급

user_id·CSRF·만료 정보만 포함

04

DB 권한 재확인

역할·활성 상태를 요청마다 조회

사내 계정 정책

@company.com 형식만 허용하고 최초 관리자는 admin@company.com으로 생성합니다.

평문을 남기지 않는 비밀번호

bcrypt 단방향 해시만 DB에 저장하고 로그인 시 해시를 비교합니다.

쿠키보다 DB 권한을 신뢰

서명 쿠키에는 user_id·CSRF·만료만 두고 역할과 활성 상태는 요청마다 DB에서 확인합니다.

선택 근거

서버 세션 저장소 없이 단순성을 유지하면서도 권한 변경은 다음 요청부터 즉시 반영됩니다.

프로젝트 단위로 소스와 사용자를 묶어 접근 경계를 만들었습니다

권한 판단 순서

1

ADMIN인가?

생성·수정·할당·업로드·분석 실행 허용

2

할당된 USER인가?

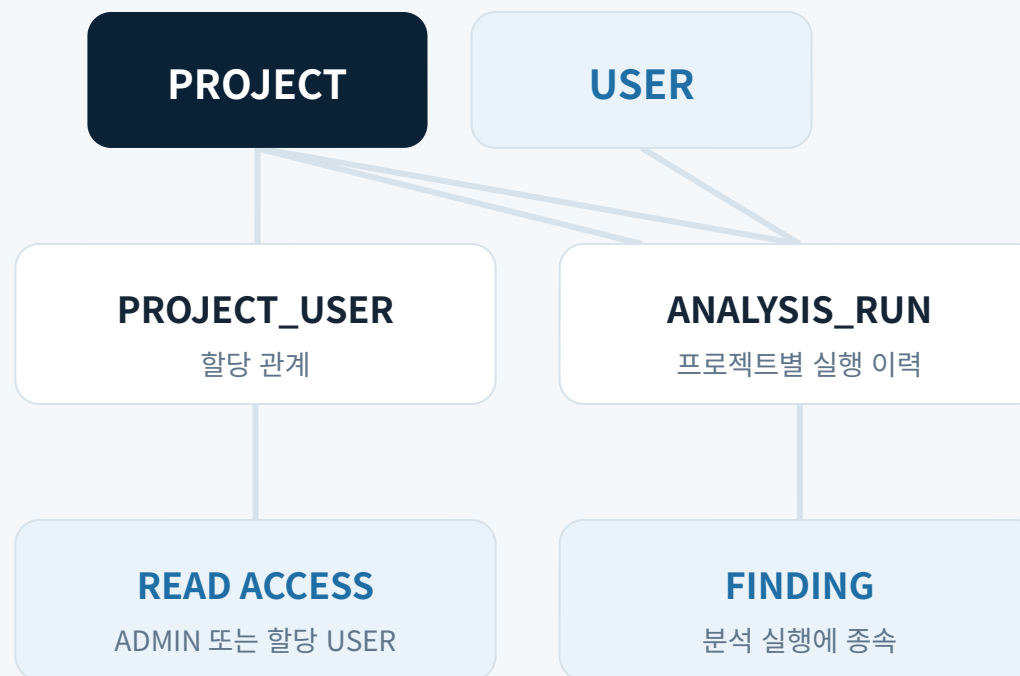
프로젝트·분석 이력·Finding 읽기 허용

3

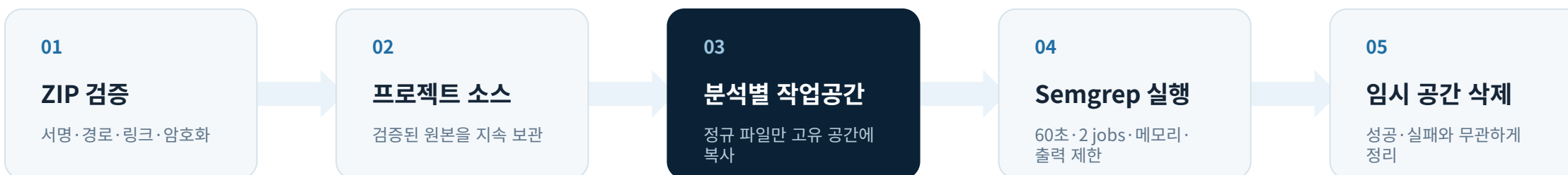
그 외 요청인가?

자원 존재를 숨기기 위해 404 반환

DB 관계로 접근을 판단



업로드 파일을 신뢰하지 않고 분석마다 복사본을 격리합니다



원본과 복사본의 차이

프로젝트 소스

다음 분석에서도 사용할 검증된 소스이므로 보관

분석 작업공간

한 번의 분석을 위한 임시 복사본이며 실행 직후 삭제

DB 경로도 다시 검증

저장된 값이 프로젝트 경계를 벗어나면 실행하지 않음

Semgrep 결과를 분석별 이력과 공통 Finding으로 남깁니다

분석 실행은 상태와 근거를 함께 남깁니다

PENDING

RUNNING

COMPLETED

FAILED

분석별 저장 정보

실행 이력

프로젝트·실행자·시작/종료 시각·오류

재현 정보

소스/규칙 SHA-256·Semgrep 버전·활성 Rule

결과 연결

AnalysisRun 1:N Finding·Rule FK

Semgrep JSON

↓ normalizer

공통 Finding

- 상대 파일 경로와 줄·열
- 심각도·신뢰도·메시지
- 근거 코드·권고·원본 결과
- 분석 시점 Rule 메타데이터

분석별 재현 정보

소스·규칙 SHA-256 / Semgrep 버전
/ 활성 Rule 목록

49개 카탈로그와 자동 탐지 범위를 분리해 과장 없이 관리합니다

49

KISA 카탈로그

공식 항목 전체 등록

8

PARTIAL 자동 탐지

3개 언어별 규칙 검증

41

지원 언어

NOT_IMPLEMENTED **Java**
JavaScript
Python

자동 탐지를 주장하지 않음

YAML은 개발자가 작성하고,
관리자는 KISA 항목 · 언어 · Rule ID 연결만 DB에
등록합니다.

카탈로그와 탐지 규칙의 역할 분리

KISA CATALOG

공식 49개 항목

ID · 명칭 · 분류 · 설명

DIAGNOSTIC_RULE

관리자 DB 매핑

언어 · Semgrep Rule
ID

YAML

개발자 관리

Semgrep이 실행

웹 애플리케이션은 YAML을 해석하거나 수정하지 않습니다.

공식 카탈로그 조회와 언어별 Rule ID 연결만 담당합니다.

중간점검을 통과했고, 남은 구현은 진단 항목 확장입니다

48

자동 테스트 통과

인증·권한·ZIP 방어·실제 Semgrep·
Finding·규칙·DB 무결성·품질 구조

남은 구현 1건

NOT_IMPLEMENTED 진단 항목 구현

현재 자동 탐지하지 않는 41개 KISA 항목을 대상으로
Semgrep 규칙과 검증 데이터를 추가합니다.

YAML 규칙 + 취약·정상 샘플 + KISA Rule ID 매핑

시연 순서



요구사항은 기능 단위로 묶어 추적할 수 있습니다

기능 묶음	관련 요구사항	구현 근거	검증
로그인·계정 보호	SFR-001·003 / DAR-002 / SEC-001·002	bcrypt·signed cookie·CSRF·DB 역할 재검증	TST-001
프로젝트·권한	SFR-003·008 / DAR-003~005·010 / SEC-003~006	ProjectUser 관계·ADMIN 쓰기·USER 읽기·404	TST-002·003
ZIP·분석 격리	SFR-008 / SEC-007~009	안전 추출·경계 재검증·분석별 작업공간·제한	TST-004·008
분석 이력·Finding	SFR-009·010 / DAR-005·006·008·009	상태·provenance·공통 결과·상대경로	TST-004·007 / QLT-003~005
KISA 규칙	SFR-011~013 / DAR-007	49개 카탈로그·8개 PARTIAL·언어별 Rule ID 매핑	TST-005·006 / QLT-002

자동 테스트는 보안 경계와 분석 흐름을 확인했습니다

01 인증·계정

ADMIN/USER 로그인, bcrypt 해시, 쿠키 위변조·만료, CSRF, 사내 이메일 정책

02 접근 권한

ADMIN 쓰기 허용, USER 쓰기 차단, 할당 프로젝트 조회, 미할당 자원 404

03 ZIP 업로드

정상 ZIP 저장, ZIP Slip·심볼릭 링크·암호화 ZIP·파일 수와 크기 제한

04 Semgrep 실행

성공·실패·timeout·출력 제한·프로세스 종료·작업공간 정리·환경변수 격리

05 Finding·규칙

정규화 필드·필터·상세·원본 결과, 49개 카탈로그, 3개 언어 실제 샘플

06 DB·품질 구조

FK·삭제 정책·마이그레이션·상대경로·모듈 책임·항목별 YAML 독립성

최신 작업 트리 기준 48개 자동 테스트 통과 · 실제 Semgrep 취약/정상 샘플 포함